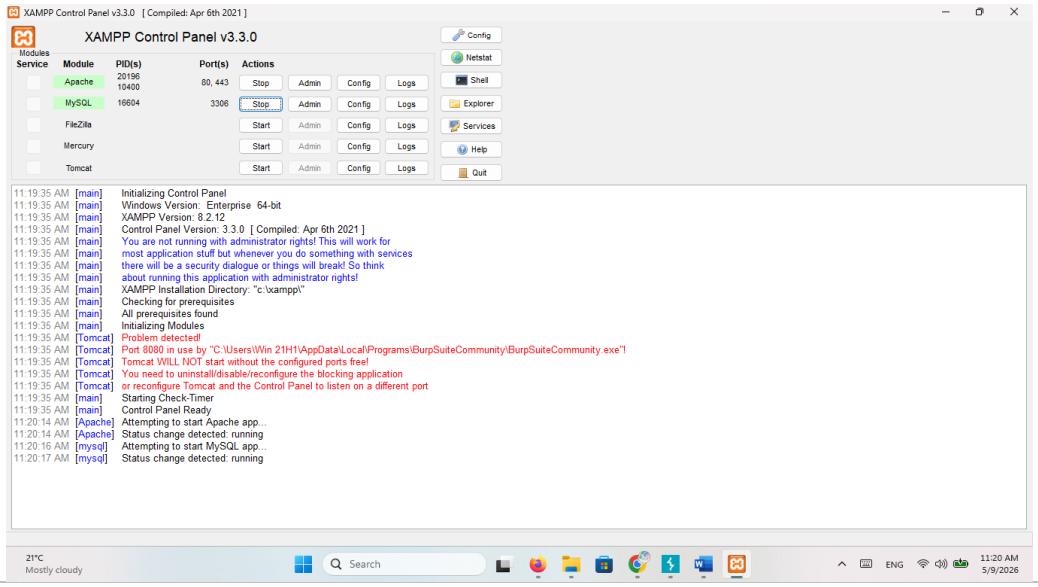
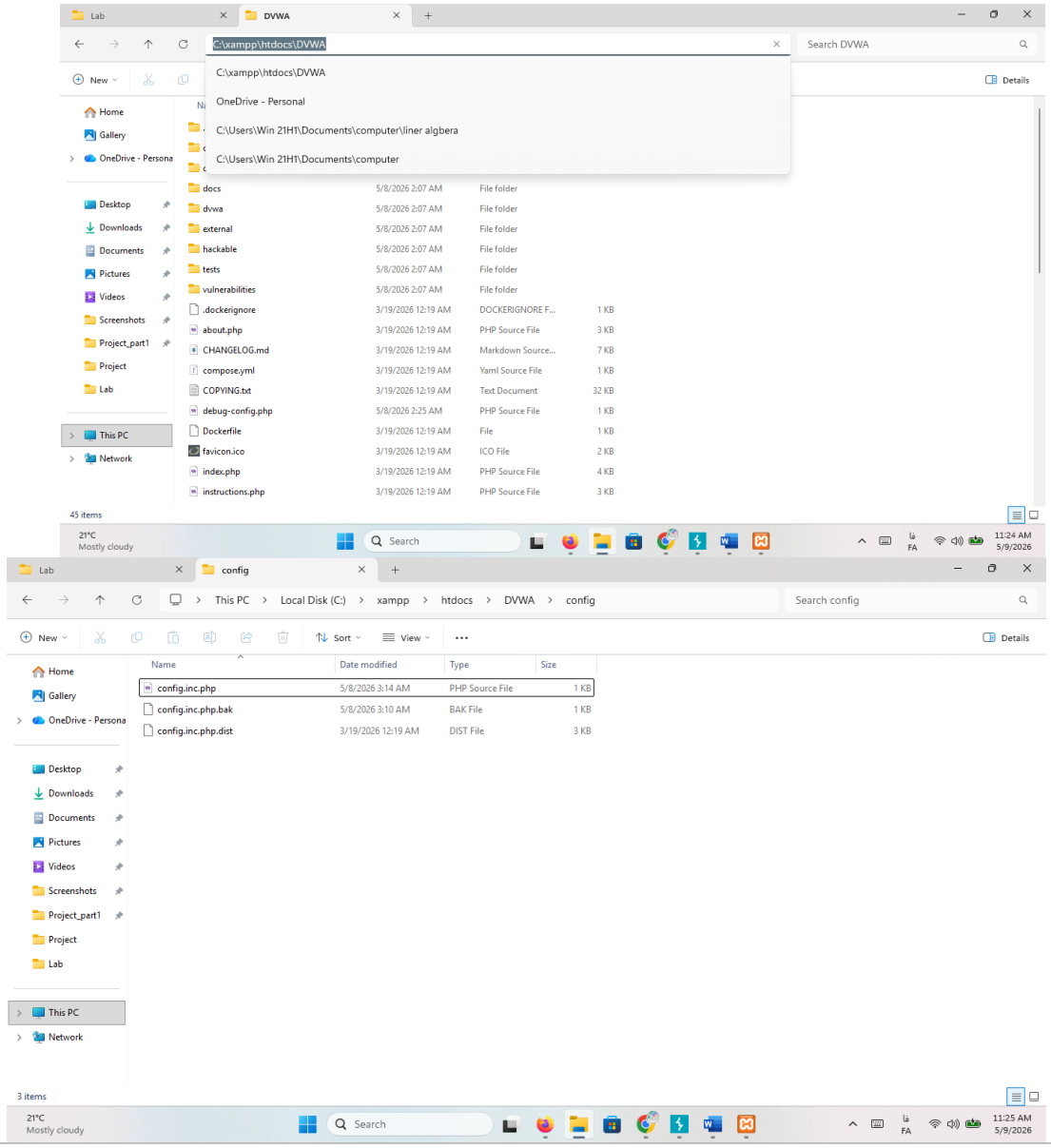
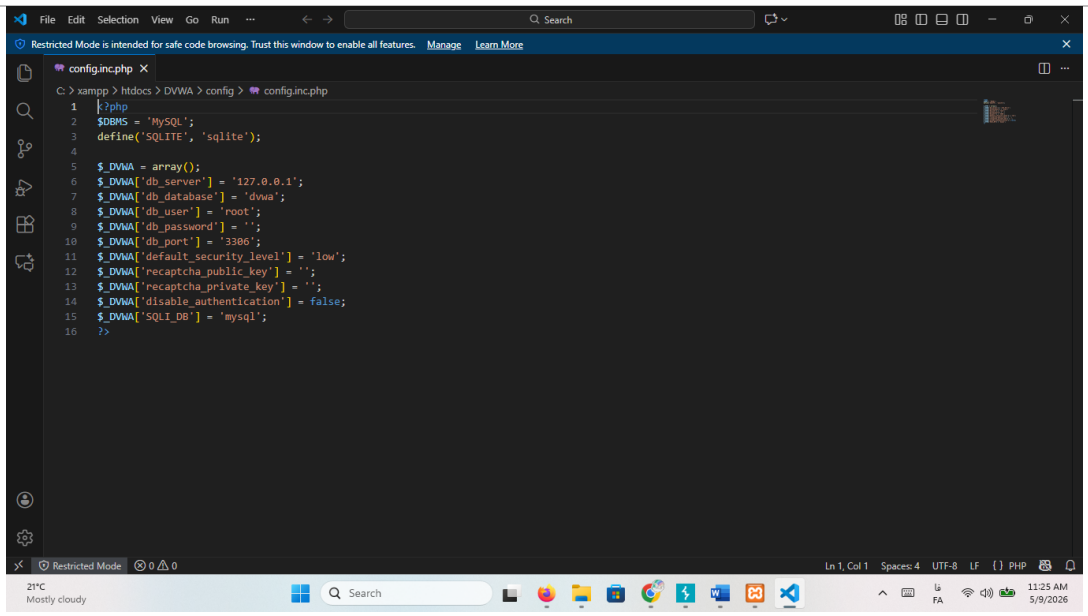
فرم گزارش کار آزمایشگاه شبکه

نام و نام خانوادگی	آتنا عسکری	شماره دانشجویی	40331033	نام و شماره آزمایش	آزمایش سوم
هدف آزمایش	آشنایی با محیطDVWA ، راه‌اندازی یک وب‌سرور محلی مبتنی بر PHP وMySQL ، پیکربندی برنامه وب، شنود ترافیک HTTPباBurp Suite ، تفسیر هدرهای درخواست/پاسخ و پیاده‌سازی حملات SQL Injection و XSS مطابق OWASP Top 10.				
ابزارهای مورد نیاز	• XAMPPبسته نرم‌افزاری شامل Apache وMySQL • DVWA (Damn Vulnerable Web Application) • Burp Suite Community EditionپروکسیMITM • مرورگر Chromium (داخلیBurp) • سیستم‌عاملWindows 10/11				
شرح آزمایش	**بخش اول : نصب و راه اندازیDVWA** **گام اول – راه‌اندازیXAMPP :** برای اجرای برنامه وب محلیDVWA ، نیاز به یک وب‌سرور و پایگاه داده داریم XAMPP .این امکان را با Apache (وب‌سرور) و MySQL(پایگاه داده) فراهم می‌کند. پس از نصبXAMPP ، دو سرویس Apache و MySQL را از طریق کنترل پنل آن استارت کردیم تا محیط اجرای DVWA آماده شود. 				

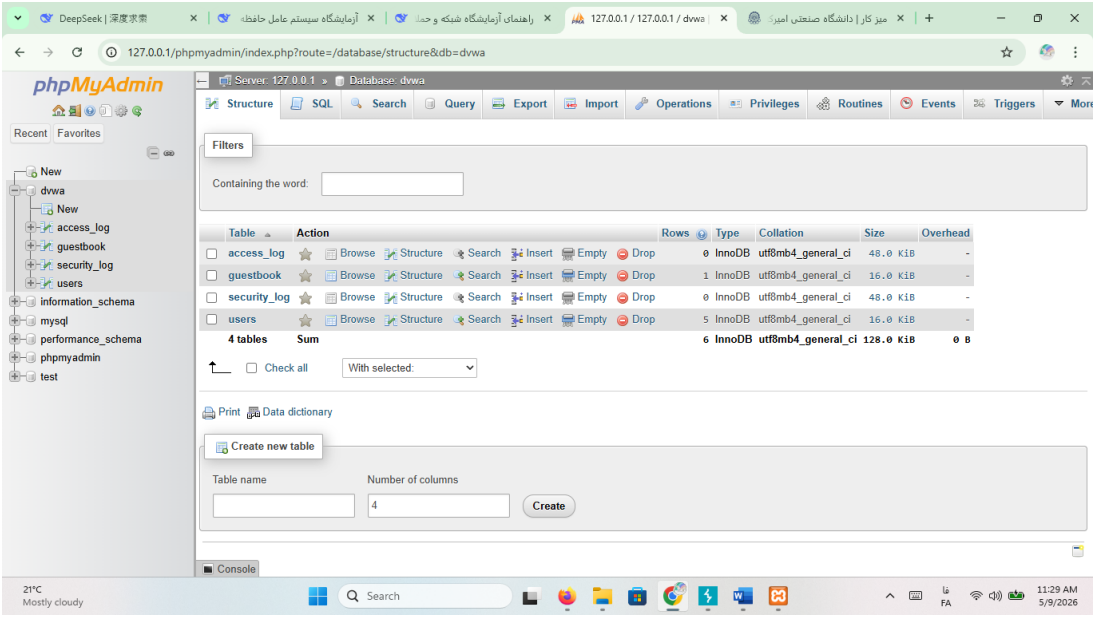
گام دوم - نصب و پیکربندیDVWA :





پس از آماده‌سازی وب‌سرور، فایل‌های DVWA در مسیر ریشه XAMPP قرار داده شدند. با کپی کردن فایل config.inc.php.distو تغییر نام آن به config.inc.php، تنظیمات اولیه اتصال به پایگاه داده انجام شد. در این تنظیمات، آدرس سرور پایگاه داده (127.0.0.1)، نام دیتابیس(dvwa) ، نام کاربری (root) و رمزعبور (خالی) مطابق با تنظیمات پیش‌فرض XAMPP تعیین گردید.

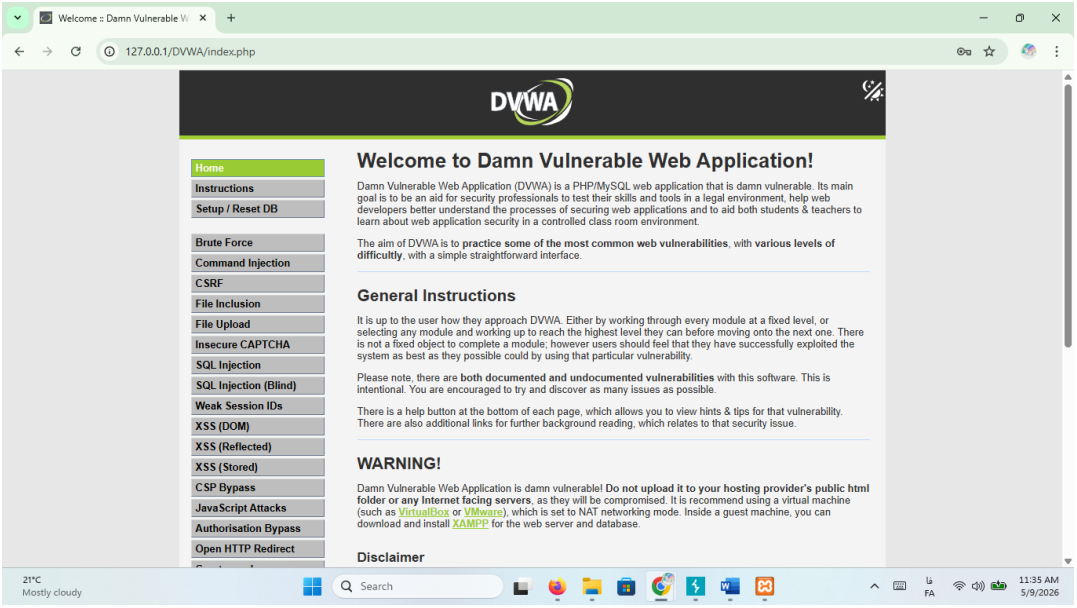
گام سوم: ایجاد پایگاه داده(Database)



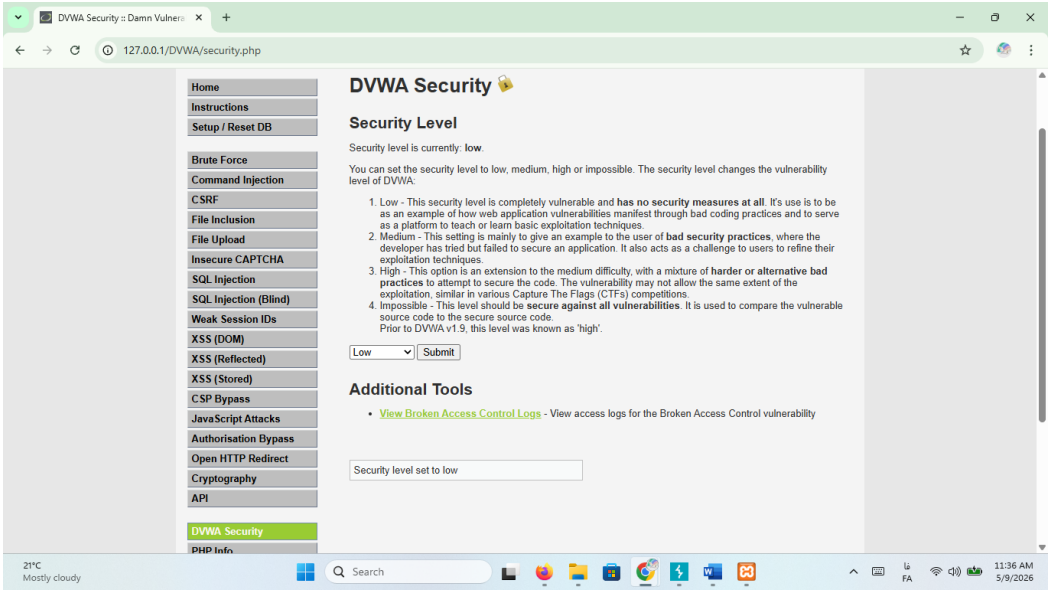
برای اتصال DVWA به پایگاه داده، از phpMyAdmin استفاده کردیم. یک پایگاه داده جدید با نام dvwaو مجموعه‌کاراکتر utf8_general_ciایجاد شد. در این مرحله، دیتابیس بدون جدول است و در مرحله بعد با اجرای اسکریپت setup.php جداول مورد نیاز ساخته خواهند شد. من چون قبلا جداول رو ساخته بودم اسامی جداول اینجا

آمده است اما اگه برای اولین بار دیتابیس ساخته می شود باید "No tables found in database" در صفحه اصلی نشان داده شود.

گام چهارم : نصب نهایی DVWA و تنظیم سطح امنیت



پس از ایجاد پایگاه داده درphpMyAdmin ، مرحله نهایی نصب DVWA از طریق مرورگر انجام شد. با مراجعه به آدرس http://localhost/DVWA/setup.phpو کلیک روی دکمه Create / Reset Database، اسکریپت نصب به صورت خودکار جداول مورد نیاز را در دیتابیس dvwaایجاد کرد. پیام‌های سبز رنگ شامل Database has been createdو Setup successfulنمایش داده شد که نشان‌دهنده موفقیت آمیز بودن نصب بود. سپس با استفاده از اطلاعات ورود admin(نام کاربری) و password(رمز عبور) وارد سیستم شدیم و صفحه اصلی DVWA با منوی آسیب‌پذیری‌ها ظاهر گردید.



پس از نصب موفقDVWA ، برای انجام حملات برنامه‌ریزی شده در آزمایش، سطح امنیت سیستم روی Lowتنظیم شد. برای این کار از بخش DVWA Securityدر منوی سمت چپ استفاده کردیم و گزینه Low را انتخاب کرده و دکمه Submitرا زدیم. پیام سبز رنگ "Security level set to low"نشان‌دهنده موفقیت این تنظیم بود. در سطحLow ، هیچ گونه مکانیزم امنیتی فعال نیست و سیستم کاملاً در برابر حملات SQL Injection و XSS آسیب‌پذیر است که این امر امکان پیاده‌سازی حملات آموزشی را فراهم می‌کند.

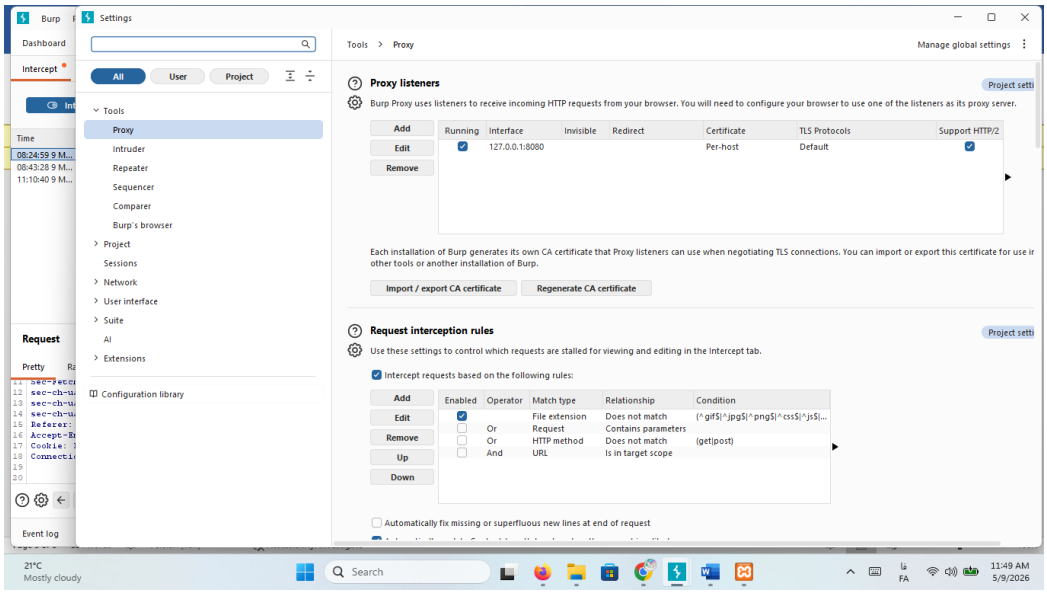
بخش دوم گزارش نصب و پیکربندیBurp Suite Community Edition

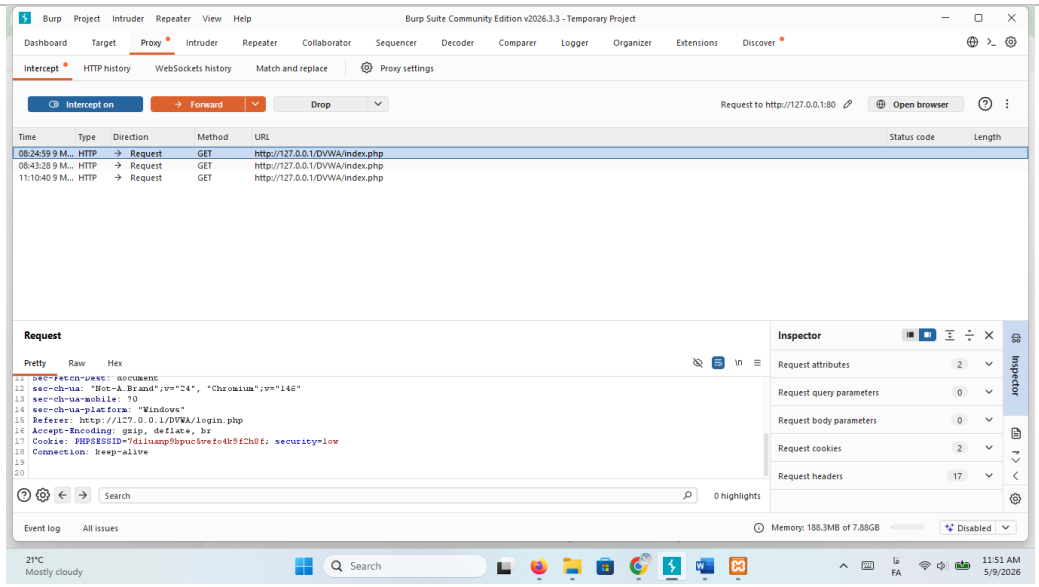
گام اول – نصب Burp Suite Community Edition

نصب Burp Suite Community Edition با اجرای فایل نصاب دریافت شده از استاد و طی مراحل Next ⟶ Next ⟶با تنظیمات پیش‌فرض انجام شد. پس از اتمام نصب، نرم‌افزار از منوی Start اجرا گردید.

گام دوم – تنظیم پروکسی و آماده‌سازی برای رهگیری

پس از اجرایBurp ، یک پروژه موقتی (Temporary Project) با انتخاب گزینه Use Burp Defaults ایجاد شد. در تب Proxy ⟶ Options، تنظیمات پروکسی به صورت پیش‌فرض روی آدرس 127.0.0.1 و پورت 8080 تأیید گردید. در تب Proxy ⟶ Intercept، دکمه Intercept روی حالت ON قرار داده شد تا آماده رهگیری درخواست‌ها باشیم.



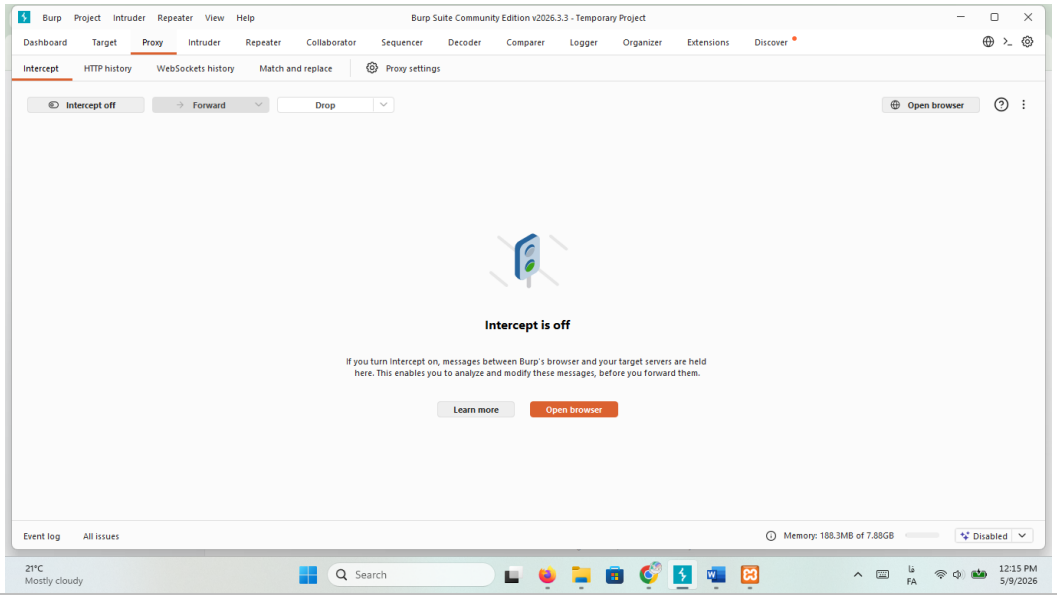


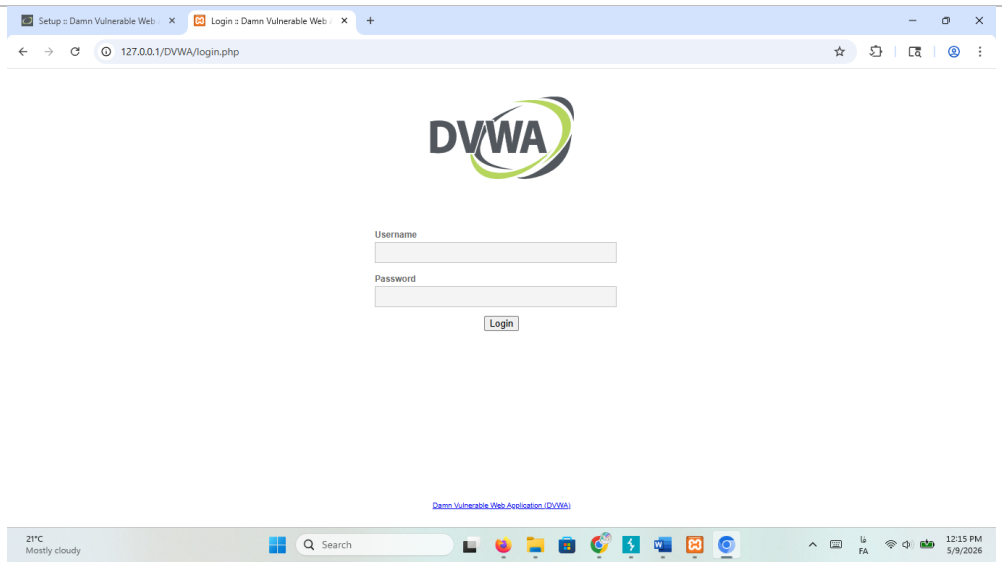
بخش سوم گزارش – شنود تر افیک و حمله MITM باBurp Suite

هدف این بخش: درک مفهوم حمله مرد میانی (MITM) با استفاده ازProxy Burp Suite ، تحلیل ساختار درخواست/پاسخ HTTP و دستکاری ترافیک.

گام اول – تنظیم پروکسی مرورگر داخلیBurp

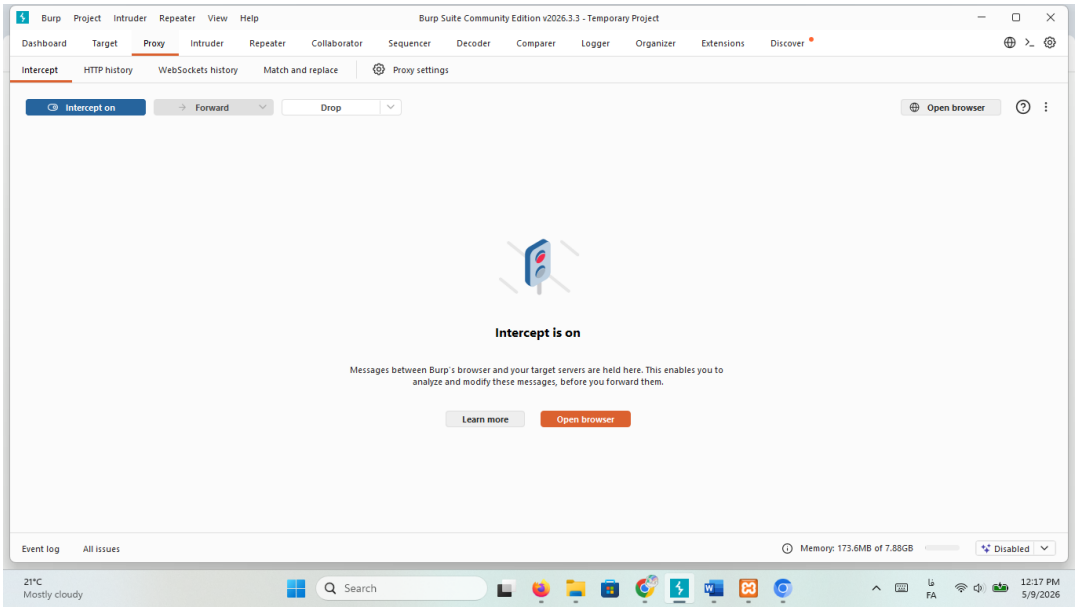
Burp Suiteدارای یک مرورگر داخلی (Chromium) است که به طور خودکار از پروکسی Burp استفاده می‌کند. با باز کردن این مرورگر، تمام ترافیک آن از Burp عبور می‌کند.





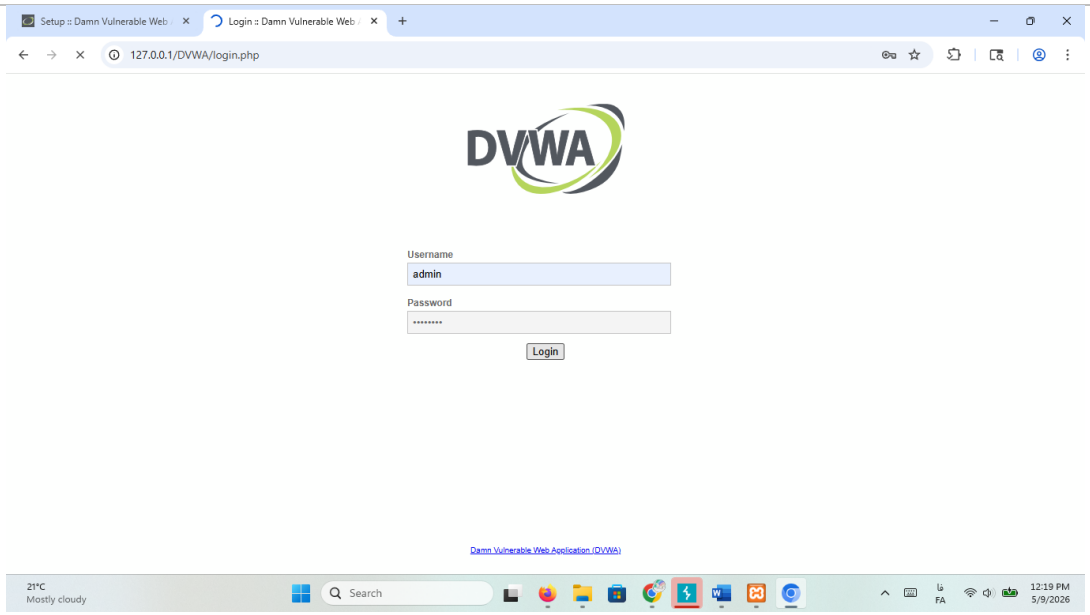
گام دوم – فعال‌سازی رهگیری(Intercept)

برای متوقف کردن درخواست‌ها قبل از رسیدن به سرور، دکمه Intercept باید در حالت ON باشد.



گام سوم – ارسال درخواست لاگین و رهگیری آن

زمانی که کاربر در فرم لاگین اطلاعات خود را وارد کرده و دکمه Login را می‌زند، مرورگر یک درخواست از نوع POST به سرور ارسال می‌کند. با فعال بودنIntercept ، این درخواست در Burp متوقف می‌شود.



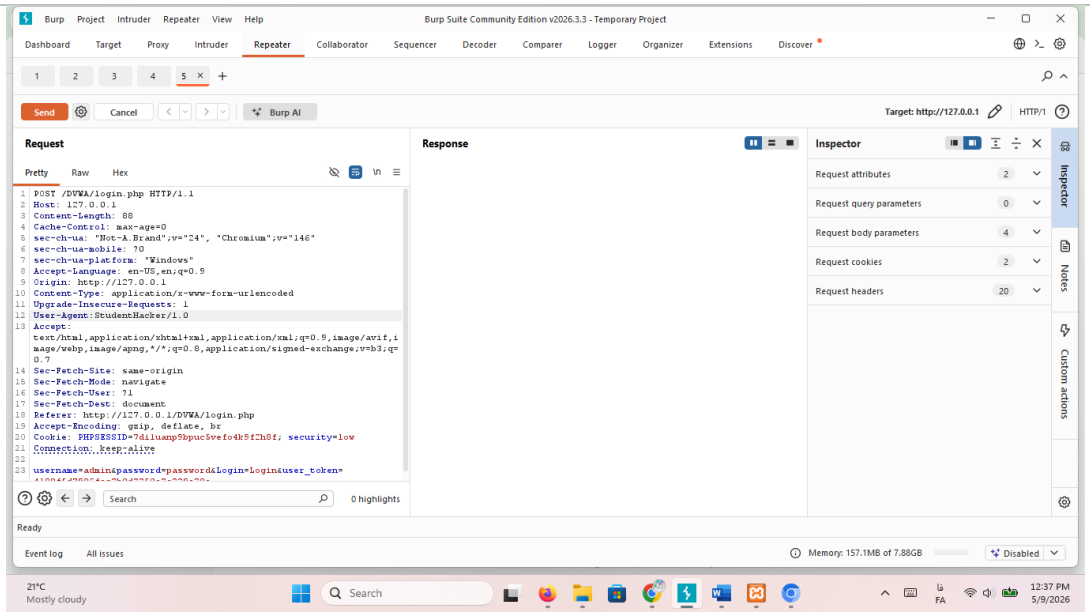
گام چهارم – تحلیل درخواستHTTP

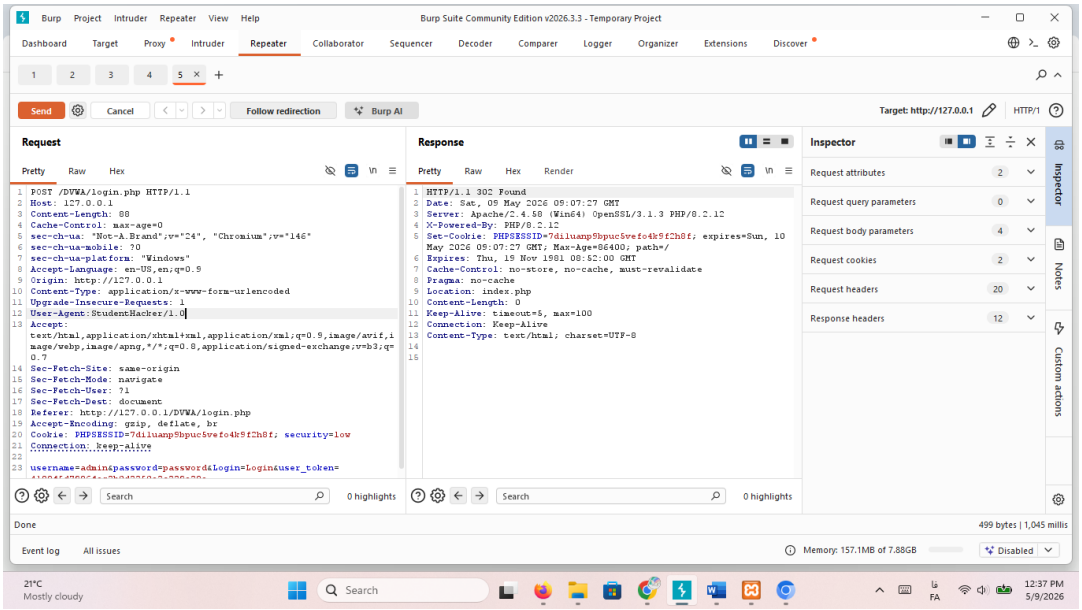
پس از متوقف کردن درخواست لاگین درBurp ، ساختار آن را بررسی کردیم. همان‌طور که در تصویر مشخص است:

- خط آغازین درخواست: POST /DVWA/login.php HTTP/1.1
- هدر Host آدرس سرور مقصد را نشان می‌دهد(127.0.0.1)
- هدر User-Agent مشخصات مرورگر و سیستم‌عامل را مشخص می‌کند
- هدر Cookie شامل PHPSESSIDبرای مدیریت نشست کاربر است
- بدنه درخواست (در پایین تصویر) به صورت فرمت application/x-www-form-urlencodedبوده و حاوی مقادیر username=adminو password=passwordاست.

این اطلاعات نشان می‌دهد که چگونه داده‌های احراز هویت به صورت واضح و بدون رمزنگاری در بدنه درخواست HTTPارسال می‌شوند.

گام پنجم – انتقال درخواست به Repeater و دستکاریUser-Agent





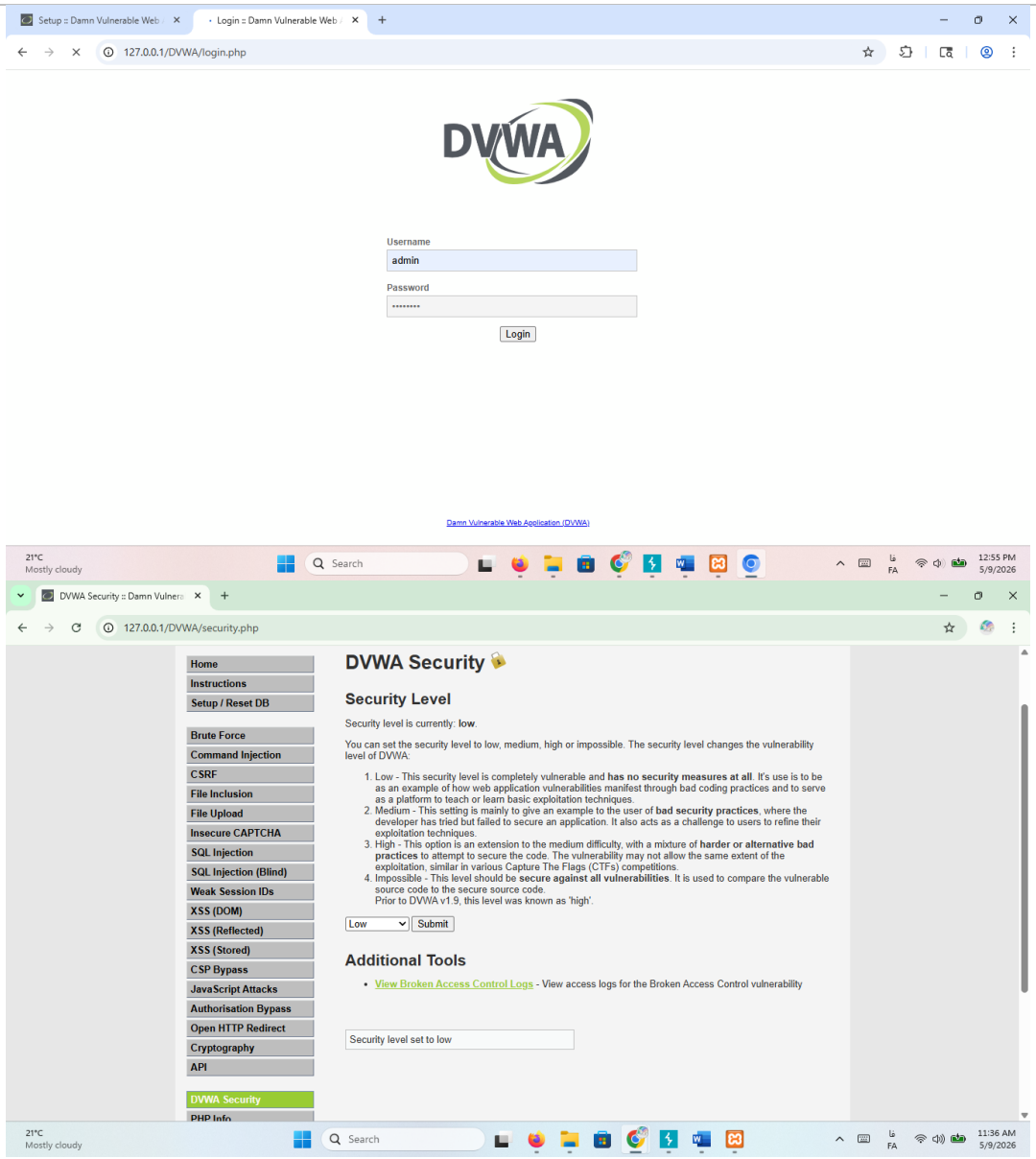
در گام بعدی، درخواست لاگین به Repeater ارسال شد. با تغییر هدر User-Agent به مقدار StudentHacker/1.0و ارسال مجدد درخواست، سرور پاسخ 302 Foundرا با هدر Location: index.phpبازگرداند. این پاسخ نشان می‌دهد که فرآیند احراز هویت با موفقیت انجام شده و کاربر به صفحه اصلی هدایت شده است. تغییر User-Agent هیچ تأثیری در نتیجه احراز هویت نداشت و این موضوع نشان می‌دهد که مهاجم در حمله مرد میانی (MITM) می‌تواند این هدر را به دلخواه جعل کند.

بخش چهارم – حملات وب SQL Injectionو XSS

گام اول: حملهSQL Injection

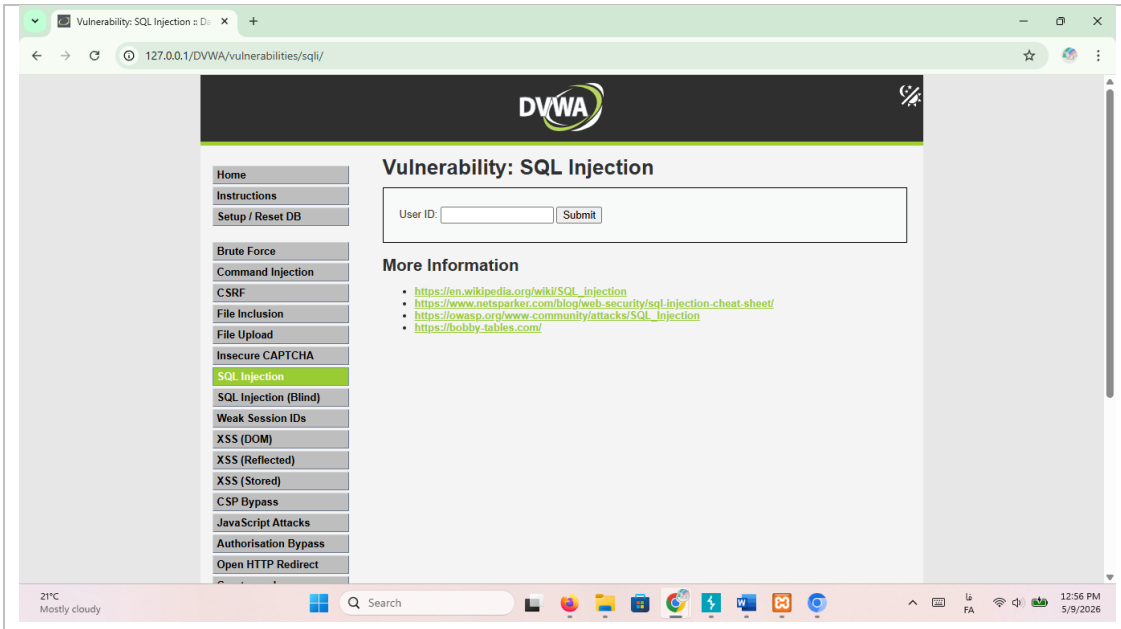
هدف: استخراج اطلاعات حساس از پایگاه داده با تزریق کد مخرب SQL در پارامتر ورودی.

گام اول – آماده‌سازی محیط (قبلاً انجام شده)



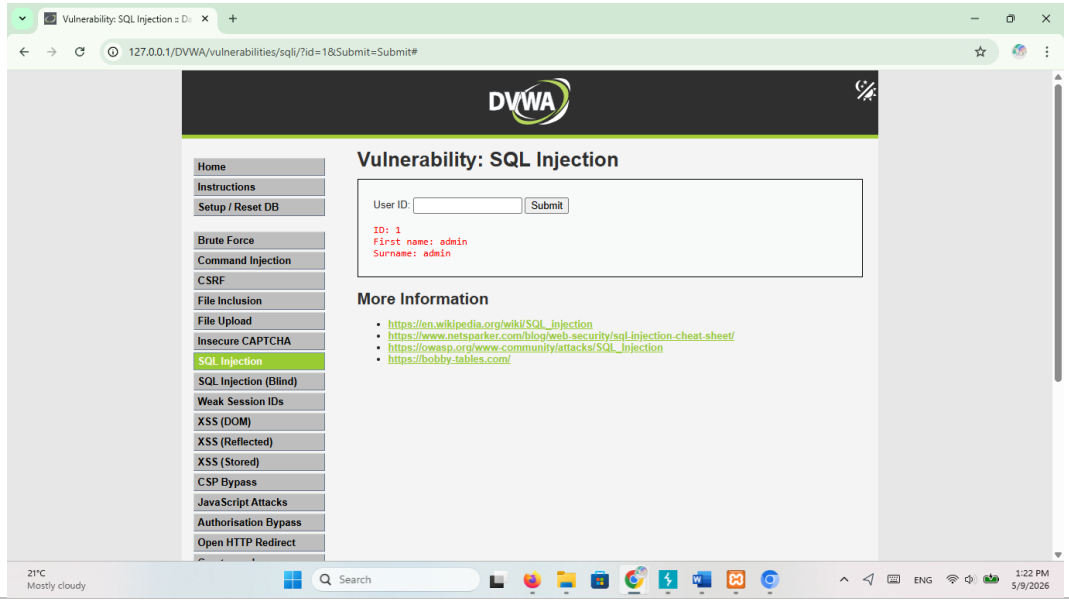
گام دوم – رفتن به بخشSQL Injection

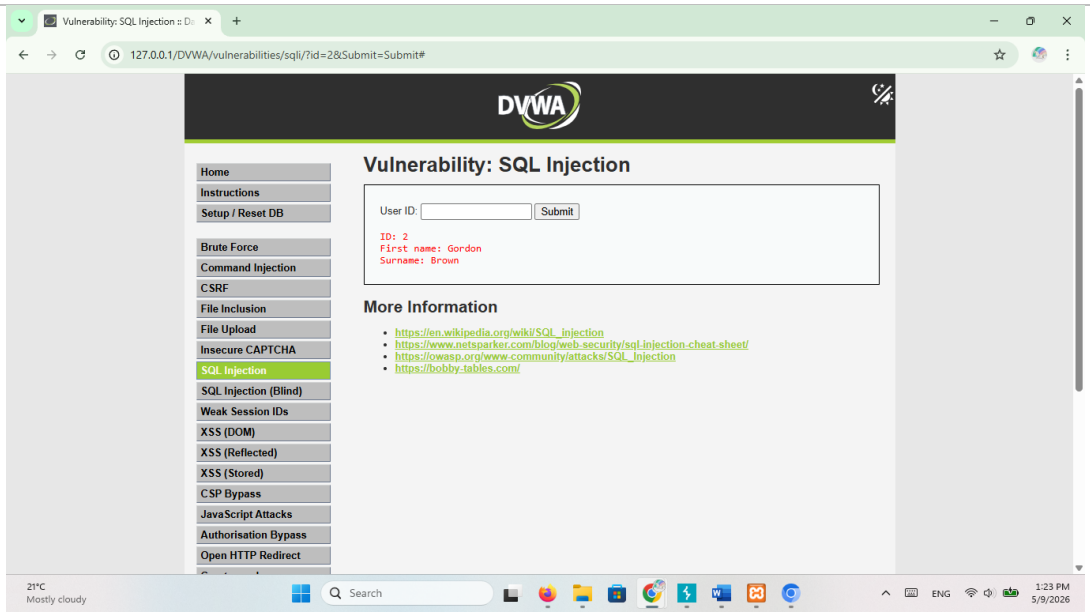
پس از ورود بهDVWA ، از منوی سمت چپ گزینه SQL Injection انتخاب شد. صفحه مربوطه شامل یک کادر ورودی برای دریافت شناسه کاربر (User ID) و یک دکمه Submit است.



گام سوم – مشاهده رفتارعادی سیستم (بدون حمله):

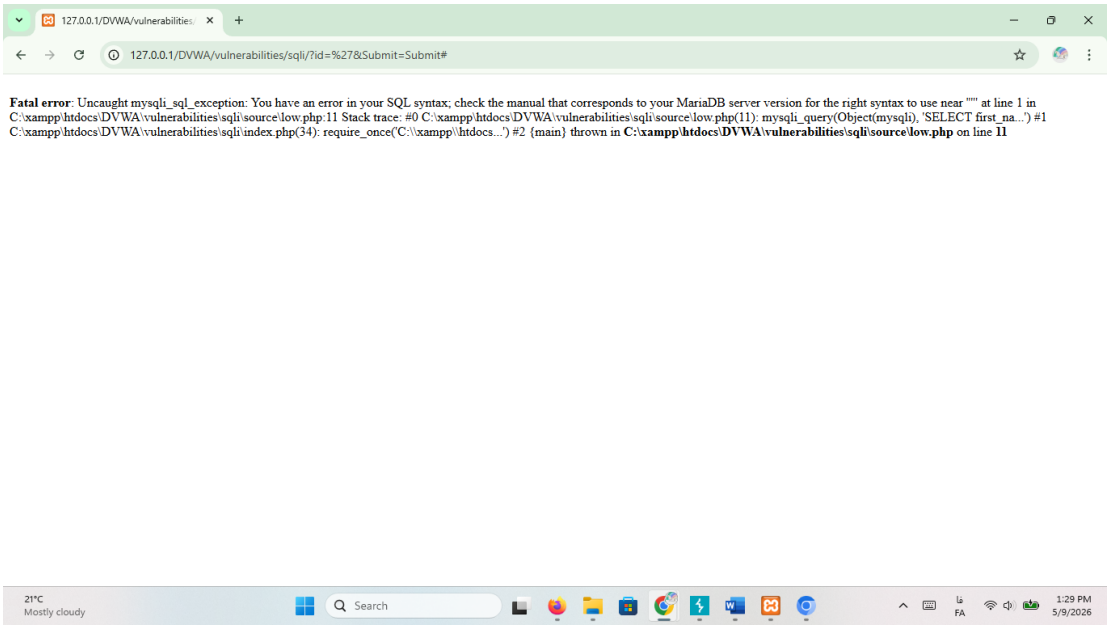
در حالت عادی و بدون حمله، با وارد کردن شناسه کاربری معتبر (مثلاً عدد ۲) در کادرUser ID ، برنامه وب اطلاعات مربوط به آن کاربر را از پایگاه داده خوانده و نمایش می‌دهد. همان‌طور که در تصویر مشاهده می‌شود، برای شناسه ۲، اطلاعات First name: Gordonو Surname: Brownنمایش داده شده است. این رفتار عادی سیستم نشان می‌دهد که برنامه در شرایط معمولی به درستی کار می‌کند.





گام چهارم – کشف آسیب‌پذیری (تست نفوذ اولیه)

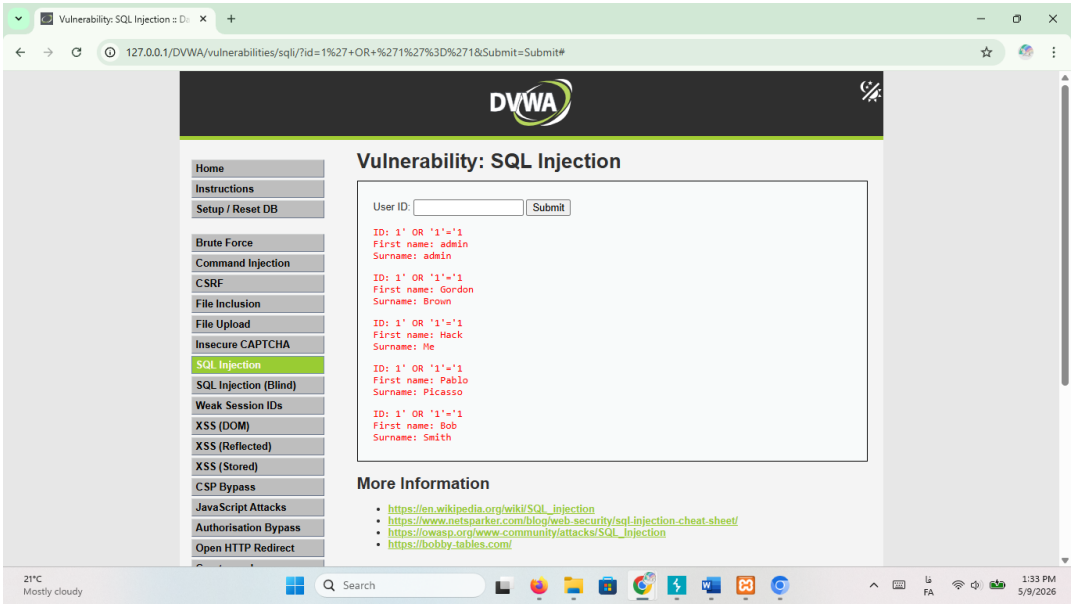
برای بررسی وجود آسیب‌پذیری تزریقSQL ، کاراکتر ' به عنوان ورودی به سرور ارسال شد. در پاسخ، صفحه خطای پایگاه داده نمایش داده شد که حاوی عبارت You have an error in your SQL syntax بود. این خطا نشان می‌دهد که ورودی کاربر بدون اعتبارسنجی و پالایش مستقیماً در کوئری SQL قرار گرفته و برنامه در برابر حملات SQL Injection آسیب‌پذیر است.



گام چهارم – اجرای حمله و استخراج تمام داده‌ها

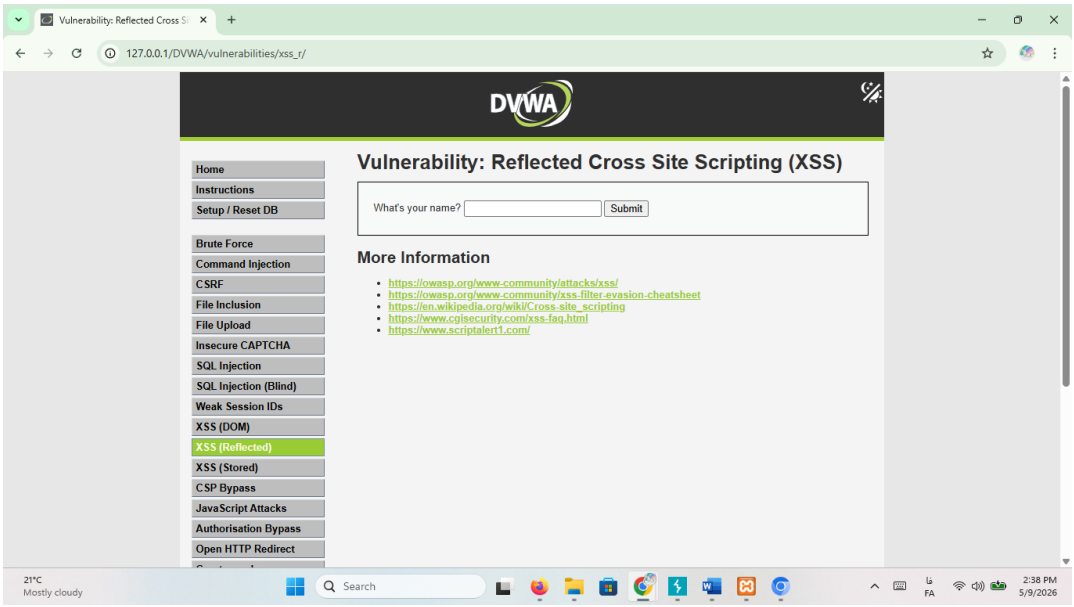
پس از شناسایی آسیب‌پذیری، پیلود 1' OR '1'='1 در کادر User ID تزریق شد. این پیلود شرط کوئری SQL را همیشه درست (True) می‌کند. در نتیجه، سیستم به جای اطلاعات یک کاربر خاص، تمام رکوردهای جدول users را نمایش داد. همان‌طور که در تصویر مشاهده می‌شود، اطلاعات تمام کاربران شامل admin, Gordon, Hacky و ... قابل

مشاهده است. این حمله نشان می‌دهد که مهاجم می‌تواند بدون نیاز به دانستن شناسه کاربری، به تمام اطلاعات ذخیره شده در دیتابیس دسترسی پیدا کند.



بخش چهارم – قسمت دوم: حمله XSS (Reflected)

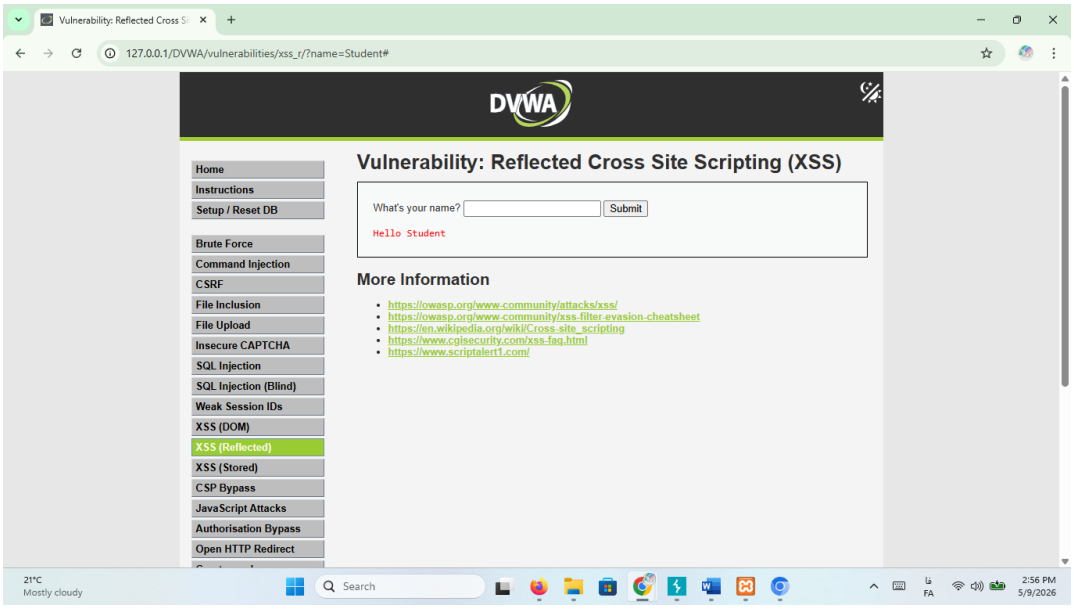
گام اول – رفتن به بخش XSS (Reflected) در DVWA



پس از ورود به DVWA ، از منوی سمت چپ گزینه XSS (Reflected) انتخاب شد. این بخش شامل یک کادر ورودی برای دریافت نام کاربر و یک دکمه Submit است. هدف این بخش، نمایش بازتاب (Reflection) ورودی کاربر در صفحه وب بدون پالایش مناسب است.

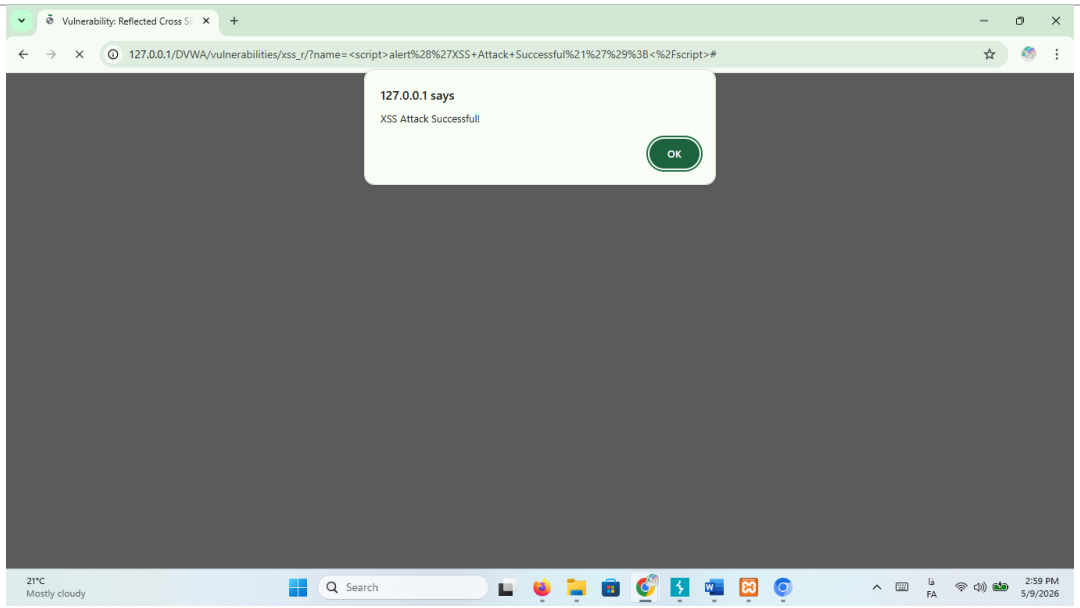
گام دوم – مشاهده رفتار عادی سیستم بدون حمله

پیش از اجرای حمله، رفتار عادی سیستم بررسی شد. با وارد کردن یک نام معمولی) مانند (Student در کادر ورودی، صفحه پیام Hello Studentرا نمایش داد. این نشان می‌دهد که برنامه وب ورودی کاربر را در خروجی HTML بازتاب می‌دهد (بدون اعمال رمزنگاری). در این حالت، ورودی کاربر به عنوان متن ساده در صفحه نمایش داده می‌شود.



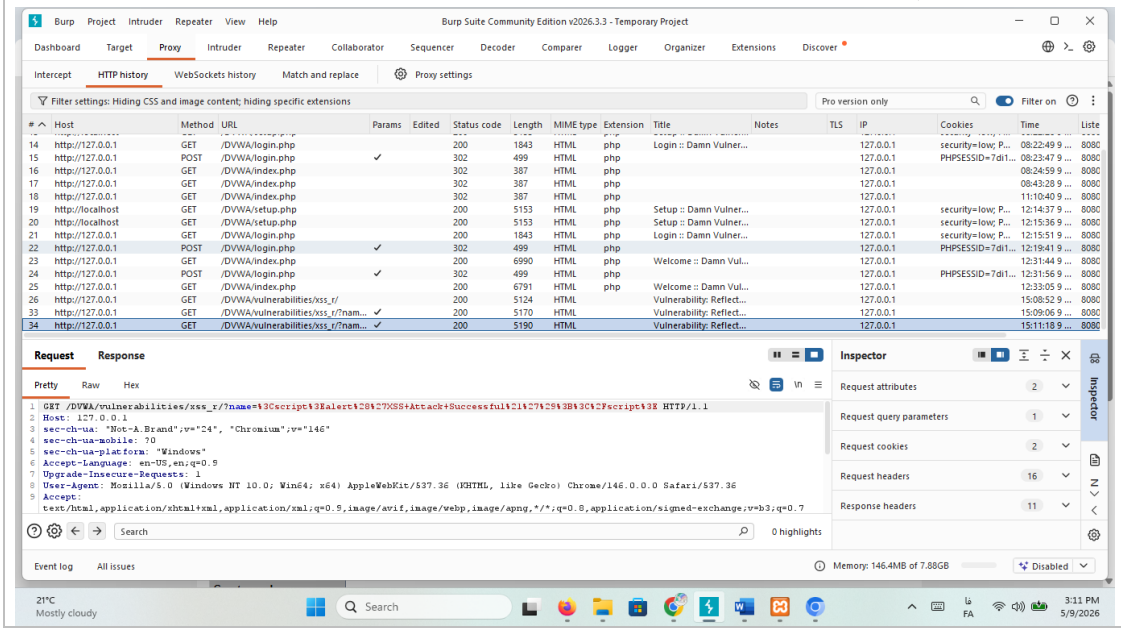
گام سوم – اجرای حمله XSS (تزریق کد جاوااسکریپت)

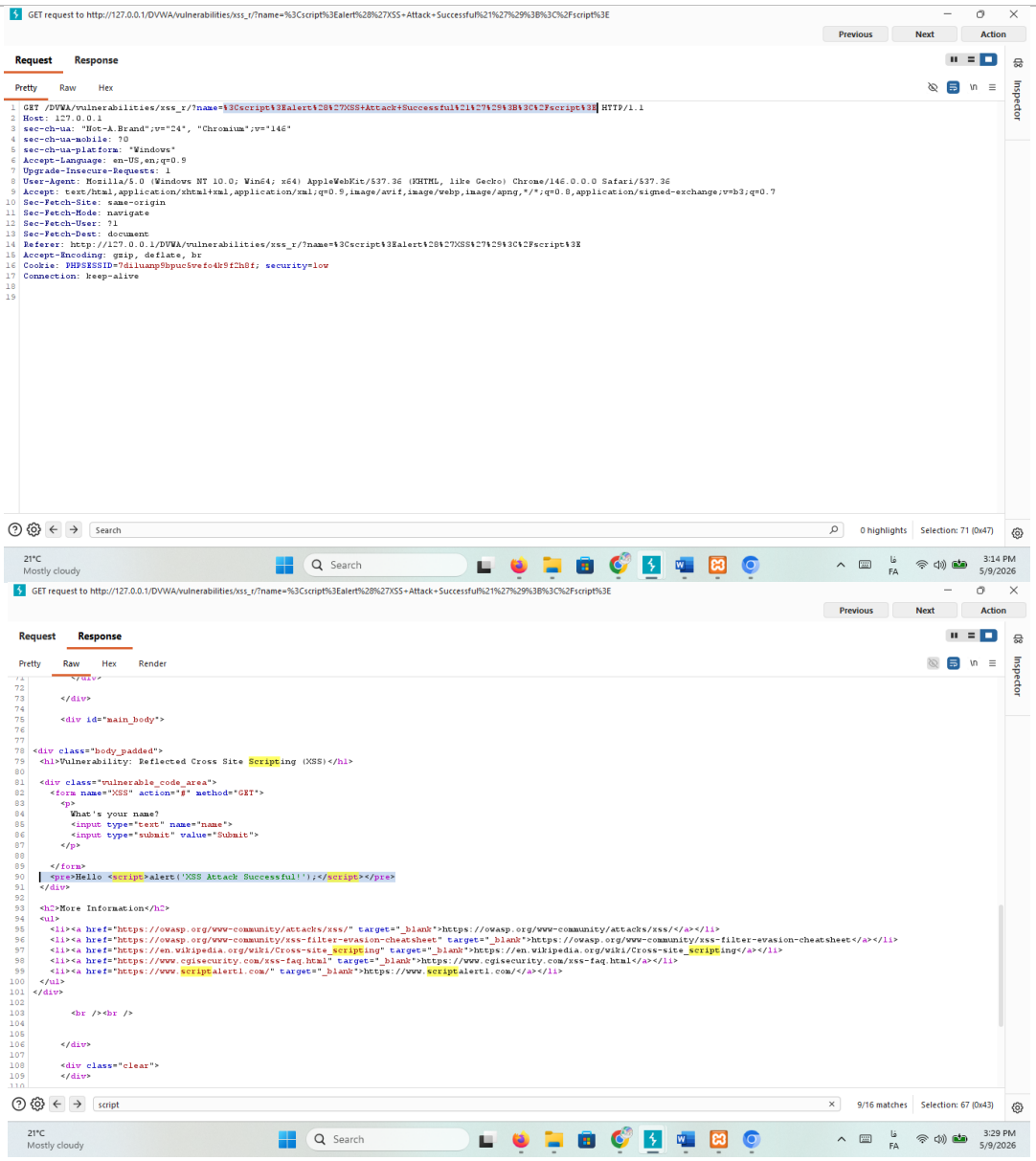
در این مرحله، به جای یک نام معمولی، کد مخرب جاوااسکریپت <script>alert('XSS Attack Successful!');</script>در کادر ورودی تزریق شد. پس از ارسال، مرورگر کد تزریق شده را به عنوان بخشی از صفحه اجرا کرد و پنجره هشدار با پیام !XSS Attack Successfulنمایش داده شد. این حمله نشان می‌دهد که برنامه وب ورودی کاربر را بدون اعتبارسنجی و encoding در خروجی HTML بازتاب می‌دهد و در برابر آسیب‌پذیری XSS (Reflected)آسیب‌پذیر است.



گام چهارم – تحلیل فنی درBurp Suite

پس از تزریق کد <script>alert('XSS Attack Successful!');</script> در کادر ورودی و کلیکSubmit ، درخواست GET حاوی این پیلود به سرور ارسال شد. همان‌طور که در تصویر مشاهده می‌شود، سرور کد تزریق شده را بدون هیچ تغییری در خروجی HTML بازتاب (Reflection) کرده است. این موضوع باعث می‌شود مرورگر کاربر، کد <script>را به عنوان کد اجرایی تفسیر کرده و پنجره هشدار را نمایش دهد. این آسیب‌پذیری از نوع Reflected XSS نشان می‌دهد که برنامه وب ورودی کاربر را بدون اعتبارسنجی و Encoding در خروجی قرار می‌دهد.





بخش پنجم – تحلیل استاندارد OWASP Top 10

OWASP Top 10 چیست؟ OWASP یک سازمان غیرانتفاعی بین‌المللی است که به امنیت نرم‌افزار تخصص دارد. این سازمان هر چند سال یک بار لیستی از ۱۰ آسیب‌پذیری بحرانی در برنامه‌های وب را منتشر می‌کند. این لیست به عنوان مرجع اصلی برای تیم‌های امنیتی، توسعه‌دهندگان نرم‌افزار و شرکت‌ها در سراسر جهان استفاده می‌شود. هدف از انتشار این لیست، آگاهی‌بخشی و اولویت‌بندی رفع آسیب‌پذیری‌ها است.

مهمترین آسیب‌پذیری‌های وب بر اساس) OWASP Top 10 نسخه 2025(

۱) Broken Access Control(کنترل دسترسی شکسته)

به معنی عدم محدودیت صحیح دسترسی کاربران به منابع و قابلیت‌های برنامه است. برای مثال، یک کاربر عادی می‌تواند به پنل مدیریتی دسترسی پیدا کند.

۲) Cryptographic Failures(شکست در رمزنگاری)

این آسیب‌پذیری زمانی رخ می‌دهد که اطلاعات حساس مانند رمز عبور یا شماره کارت بانکی به صورت رمز نشده (Plaintext) ذخیره یا منتقل شوند. در این آزمایش، رمز عبور در درخواست POST به صورت واضح قابل مشاهده بود.

۳) Injection (تزریق کد مخرب)

یکی از رایج‌ترین و خطرناک‌ترین حملات وب است. در این نوع حمله، مهاجم کدهای مخرب خود را از طریق ورودی‌های برنامه به سیستم تزریق می‌کند SQL Injection .و XSSهر دو در این دسته قرار می‌گیرند. در این آزمایش، هر دو حمله با موفقیت پیاده‌سازی شدند.

۴) Insecure Design (طراحی ناامن)

به ضعف‌های موجود در معماری و طراحی برنامه اشاره دارد که قبل از نوشتن کد ایجاد می‌شوند. این نوع آسیب‌پذیری با روش‌های معمول تست نفوذ قابل شناسایی نیست.

۵) Security Misconfiguration (پیکربندی اشتباه امنیتی)

زمانی رخ می‌دهد که تنظیمات امنیتی سرور، پایگاه داده یا برنامه به درستی انجام نشده باشد. در این آزمایش، تنظیم سطح امنیت DVWA روی Low نمونه‌ای از این آسیب‌پذیری است.

۶) Vulnerable and Outdated Components (اجزای آسیب‌پذیر و قدیمی)

استفاده از کتابخانه‌ها، فریمورک‌ها یا سیستم‌عامل‌هایی که وصله‌های امنیتی آنها نصب نشده است، می‌تواند منجر به نفوذ مهاجم شود.

۷) Identification and Authentication Failures (شکست در احراز هویت)

ضعف در فرآیند شناسایی و احراز هویت کاربران، مانند عدم محدودیت تعداد دفعات لاگین ناموفق، استفاده از رمزهای ضعیف یا نبود احراز هویت دو مرحله‌ای.

۸) Software and Data Integrity Failures (شکست در یکپارچگی نرم‌افزار و داده)

زمانی رخ می‌دهد که نرم‌افزار یا داده‌ها بدون تأیید صحت و امنیت به‌روزرسانی یا منتقل می‌شوند.

۹) Security Logging and Monitoring Failures (شکست در لاگ‌گیری و نظارت)

نداشتن لاگ‌های کافی و عدم پایش صحیح رویدادهای امنیتی باعث می‌شود حملات دیر یا هرگز شناسایی نشوند.

۱۰)Server-Side Request Forgery (SSRF)

در این حمله، مهاجم سرور را مجبور می‌کند به آدرس‌های دلخواه او درخواست ارسال کند و از این طریق به منابع داخلی دسترسی پیدا کند.

نتیجه-گیری	در این آزمایش، ابتدا محیط وب محلی DVWA را با استفاده از XAMPP راه‌اندازی کرده و آن را به پایگاه داده MySQL متصل نمودیم. سپس با استفاده از ابزار Burp Suite به عنوان یک پروکسی مرد میانی(MITM) ، ترافیک HTTP ارسالی به سرور را شنود کرده و ساختار درخواست و پاسخ احراز هویت را تحلیل نمودیم. در ادامه، با تنظیم سطح امنیت DVWAرویLow ، دو حمله رایج وب شامل SQL Injection و (Reflected) XSS را با موفقیت پیاده‌سازی کردیم. حمله SQL Injectionاز طریق تزریق 1' OR '1'='1منجر به نمایش تمام رکوردهای دیتابیس شد و حمله XSS با تزریق کد (...)<script>alertباعث اجرای کد مخرب در مرورگردید. در پایان، این حملات با استاندارد OWASP Top 10 مطابقت داده شده و راهکارهای امنیتی مناسب برای پیشگیری از آنها ارائه گردید.